



SAN-log_it

08.06.2026

Auteur : Benoît Robart

EBIOS RM de l'ESN SAN-log_it

SAN-log_it
4 Rue de l'Espérance
91800 Brunoy

CHAPITRE 1 – Description de l'entreprise

Contexte : Identité et Positionnement

Titre

SAN-log_it – Administration systèmes & réseaux
Structure individuelle – activité en consolidation

Contenu

- **Raison sociale:** Créée depuis le 1er mars 2024, la PME développe des projets sous forme de labs, sous-traite avec les ESN pour des missions ponctuelles à durée déterminée.
- **SIRET:** Identifiant SIRET: 987 619 145 00012

date de création : 1er mars 2024,
- **Gérant :** André SERVILLE
- **Nature de l'activité :** Elle prospecte:
 - De l'infogérance afin de développer son activité.
 - Elle installe, configure et administre les machines depuis On-Premise (sur-site), et sur cloud.
 - Elle peut organiser des sessions de formation aux entreprises qui manifestent le besoin de former leurs utilisateurs.

Identités de la structure :

SAN-log_it est une structure indépendante spécialisée dans l'administration systèmes et réseaux.

Créée en mars 2024 et enregistrée sous le **numéro SIRET 987 619 145 00012**, l'activité consiste à concevoir, déployer et administrer des infrastructures informatiques pour des environnements de petite et moyenne taille.

L'activité s'appuie sur des laboratoires techniques permettant de tester des architectures systèmes et réseaux avant leur déploiement en environnement réel.

Contexte : Cadre juridique et réglementaire

Cadre réglementaire et conformité¹

L'activité de **SAN-log_it** s'inscrit dans un cadre réglementaire lié à la gestion des systèmes d'information et à la protection des données.

Les principales références réglementaires prises en compte sont :

RGPD – Règlement Général sur la Protection des Données

- Règlement européen encadrant la collecte et le traitement des données personnelles.
- Obligation de sécurité des traitements.
- Principe de minimisation des données.

Dans le cadre des missions techniques, **SAN-log_it** applique les principes suivants :

- **Limitation des accès aux données.**
- **Journalisation des accès administrateurs.**
- **Sécurisation des flux réseau.**
- **Sauvegarde et intégrité des données.**

NIS2 – Directive européenne sur la cybersécurité

La directive NIS2 impose aux organisations critiques :

- La gestion des risques cyber.
- La notification d'incidents.
- La mise en place de mesures de sécurité techniques.

Les architectures proposées prennent en compte :

- Segmentation réseau.
- Journalisation.
- Supervision.
- Détection d'intrusion.

¹ La conformité **RGPD** et **NIS2** de **SAN-log_it** fait l'objet d'un document dédié : **Annexe B — Conformité RGPD/NIS2**, avec périmètre des traitements, **mesures techniques article 32**, positionnement **compliance-ready NIS2** et **tableau des référentiels réglementaires (RGPD, NIS2, DSA, CIS, SANS)**.



DSA – Digital Services Act Le DSA concerne principalement les plateformes numériques et la responsabilité sur les contenus numériques.

Dans le cadre d’infrastructures hébergeant des services web, la conformité passe par :

- La traçabilité.
- La gestion des accès.
- La conservation des journaux systèmes.

Recommandations ANSSI

Les architectures techniques peuvent s’appuyer sur :

- Les guides d’hygiène informatique de l’ANSSI.
- Les référentiels de sécurité pour les PME.
- Les bonnes pratiques de **gestion des identités et des accès**.

CIS Benchmarks

Les configurations systèmes peuvent être comparées aux référentiels :

- CIS Benchmarks **Windows**.
- CIS Benchmarks **Linux**.
- CIS Benchmarks **réseau**..

Statut : juridique de l'entreprise

Statut juridique de l'entreprise

SAN-log_it est une structure indépendante spécialisée dans l'administration des systèmes et des réseaux informatiques.

L'entreprise est enregistrée sous le numéro **SIRET 987 619 145 00012** et a été créée le **1er mars 2024**.

La structure fonctionne actuellement sous la forme d'une **entreprise individuelle**, permettant de proposer des prestations techniques ponctuelles dans les domaines suivants :

- Administration systèmes et réseaux.
- Déploiement d'infrastructures informatiques.
- Mise en place de solutions de supervision et de sécurité.

Cette forme juridique permet une grande flexibilité dans la réalisation de missions techniques pour des entreprises de petite et moyenne taille.

Responsabilité et cadre contractuel

Les interventions réalisées par **SAN-log_it** s'inscrivent dans un cadre contractuel défini avec les clients.

Les prestations concernent principalement :

- L'installation d'infrastructures informatiques.
- La configuration de services systèmes et réseaux.
- La sécurisation des infrastructures existantes.

Certaines activités ne sont pas réalisées directement par la structure et peuvent être confiées à des partenaires spécialisés, notamment :

- Audits réglementaires (**RGPD, ISO 27001**).
- Développement applicatif.
- Infogérance permanente avec engagement de niveau de service (**SLA**).

Constitution d'activité de SAN-log_it:

Infrastructure:

- **Serveurs :**
 - **HP ProLiant DL380** hébergeant des machines virtuelles (VMs) : **Windows Server, Debian, Ubuntu, Kali.**
- **Stockage :**
 - **NAS Synology** dédié à la sauvegarde et au stockage des données.
- **Équipements réseau :**
 - **Switch Cisco CBS350.**
 - **Pare-feu pfSense.**

Niveau de Maturité Cybersécurité :

Niveau	Critères	Position SAN_log-It
1	Absence de mesures formalisées	Dépassé
2	Mesures de base (mises à jour, antivirus)	Dépassé
3	Supervision active + segmentation réseau	Atteint
4	Politique de sécurité formalisée + certification	En cours
5	Audit continu + SMSI certifié	Non atteint

- **Estimation :** **Niveau 3/5** selon la grille ANSSI.
- **Points forts :**
 - **Supervision** active (**Prometheus/Grafana**).
 - **Détection** d'intrusions (**IDS : Suricata**).
- **Points d'amélioration :**
 - **Absence** de certification officielle.
 - **Politique de mots de passe** non formalisée.

Propositions d'Amélioration :

- **Certifications :** Engager une démarche de certification (ex : **ISO 27001, SOC 2**).
- **Politiques de sécurité :** Formaliser une politique de mots de passe et un plan de réponse aux incidents.
- **Supervision avancée :** Compléter la supervision avec **un SIEM** (ex : **ELK Stack**) pour une vision unifiée des logs.

Objectifs d'activité de SAN-log_it:

Domaines d'intervention :

- **Administration systèmes (Windows / Linux) :**
Gestion et configuration de serveurs Windows et Linux incluant :
 - Active Directory.
 - DNS.
 - DHCP.
 - Virtualisation de laboratoires systèmes.

- **Réseaux locaux :**
Conception et test d'architectures réseau comprenant :
 - Routage IP.
 - VLAN.
 - Relais DHCP.
 - Segmentation réseau.

- **Services d'infrastructure :**
Mise en place d'environnements hybrides incluant :
 - Serveurs physiques.
 - NAS de stockage.
 - Machines virtuelles.
 - Laboratoires virtualisés.

- **Sécurisation périmétrique :**
Mise en œuvre de dispositifs de sécurité réseau :
 - Firewall pfSense.
 - IDS/IPS.
 - Segmentation réseau.

Cette section constitue un préambule à l'analyse EBIOS RM proprement dite

Nous y identifierons les caractéristiques structurelles de SAN-log_it susceptibles d'influencer à la fois, la vraisemblance et la gravité des scénarios de risque.

Notamment la concentration des accès, l'unicité de certains supports critiques et l'absence de dispositifs de sécurité formalisés seront détectées.

Grille d'évaluation des SO :

Dans la méthode EBIOS Risk Manager (version ANSSI, pas seulement la grille), les **SO** sont des **Scénarios Opérationnels**. Ils décrivent comment une menace se concrétise sur un actif.

Grille SO :

Code SO	Vraisemblance	Gravité	Niveau de risque
SO1	Élevée	Critique	Critique
SO2	Moyenne	Critique	Critique
SO3	Moyenne	Critique	Critique
SO4	Faible à moyenne	Élevée	Élevé
SO5	Moyenne	Élevée	Élevé
SO6	Faible (si pas d'exposition web)	Élevée	Moyen à Élevé
SO7	Faible (mais réelle)	Critique	Élevé

Pour SO7 : probabilité faible, mais impact critique → risque Élevé (et non Critique, car la vraisemblance est très faible)

Pour chaque SO : matrice de criticité simplifiée (EBIOS-compatible)

Niveau de risque : Critique Élevé, Moyen, Faible

Détail des Scénarios Opérationnels (SO) :

Chaque scénario est évalué selon deux axes

- **Vraisemblance** (probabilité d'occurrence).
- **Gravité** (impact maximal sur l'activité).

Code SO	Intitulé du scénario	Vraisemblance	Gravité	Niveau de risque	Commentaire opérationnel
SO1	Compromission des comptes administrateurs	Élevée	Critique	Critique	Accès administrateur = périmètre complet. Absence de MFA et politique de mots de passe non formalisée (A07). Concentration des privilèges (A01).
SO2	Ransomware sur le NAS unique	Moyenne	Critique	Critique	NAS Synology unique assurant à la fois stockage et sauvegarde. Défaut de conception (A06) – pas de séparation des fonctions, pas de copie hors-ligne.
SO3	Rebond supply-chain vers les clients	Moyenne	Critique	Critique	Accès aux infrastructures clientes (on-premise + cloud) via missions ESN. Risque de rebond consacré par l'OWASP 2025 (A03 – Software Supply Chain Failures). Impact réputationnel et contractuel majeur.
SO4	Contamination du laboratoire vers la production	Faible à moyenne	Élevée	Élevé	VM Kali sur le même hyperviseur (HP ProLiant) que les VMs de production. Absence de cloisonnement physique ou logique (A06 – Insecure Design).
SO5	Défaut de détection / perte de traçabilité	Moyenne	Élevée	Élevé	Absence de SIEM centralisé (seule supervision Prometheus/Grafana). Retard dans la réaction aux incidents (A09 – Logging & Alerting Failures).
SO6	Défaillance sécuritaire en cas d'erreur inattendue (« fail open »)	Faible (selon exposition web)	Élevée	Moyen à Élevé	Services exposés ou cloud mal configurés (A02 – Security Misconfiguration) ou mauvaise gestion des erreurs (A10 – Mishandling of Exceptional Conditions). À prioriser si des services web sont ouverts.
SO7	Indisponibilité du gérant (actif humain unique)	Faible (mais réelle)	Critique	Élevé	Entreprise individuelle : pas de backup humain sur les fonctions critiques (accès racine, mots de passe, firewall, reprise). La concentration des accès aggrave la vulnérabilité (A01 + A07).

- 
1. La **structure individuelle / gérant unique** (André SERVILLE, entreprise individuelle) → c'est la racine de **SO7** (indisponibilité du gérant) et un facteur aggravant de concentration des accès.

Cela signifie :

- **Pas de backup humain** sur les fonctions critiques (accès racine, mots de passe, configurations firewall, reprise après incident).
- Si le gérant est **malade, en arrêt, bloqué ou victime d'un accident**, il n'y a **personne d'autre** capable de :
 - **Restaurer un accès.**
 - **Réinitialiser un mot de passe maître.**
 - **Intervenir sur un serveur ou un pare-feu bloqué.**

Grille OWASP Top 10 2025 :

<https://owasp.org/Top10/2025/>

Code	Catégorie
A01:2025	Broken Access Control (inclut les SSRF)
A02:2025	Security Misconfiguration
A03:2025	Software Supply Chain Failures
A04:2025	Cryptographic Failures
A05:2025	Injection
A06:2025	Insecure Design
A07:2025	Authentication Failures
A08:2025	Software or Data Integrity Failures
A09:2025	Security Logging & Alerting Failures
A10:2025	Mishandling of Exceptional Conditions

2. L'**accès aux infrastructures clientes** (on-premise + cloud, missions ponctuelles via ESN) → c'est le cœur du risque de rebond supply-chain (**SO1, SO3**) et ce que l'**OWASP 2025** vient justement de consacrer.

L'**OWASP Top 10 2025** est utilisé comme référentiel de vulnérabilités génériques pour qualifier la surface technique exposée lors de la construction des **scénarios opérationnels**

(atelier 4). Chaque vulnérabilité est mise en correspondance avec des sources de menace et des mesures de maîtrise existantes

Chaque vulnérabilité **OWASP** est mise en correspondance avec :

- Des **sources de menace** (externe, interne, accidentelle, malveillante) ;
- Des **mesures de maîtrise existantes** (contrôles techniques, organisationnels) ;
- Des **mesures complémentaires** issues des recommandations OWASP.

Constats actuels:

- **NAS unique.**
- **Kali en prod.**
- **Absence MFA, mots de passe non formalisés.**

On peut **directement les relier à des catégories OWASP 2025**.

Constat technique	Catégorie OWASP 2025 associée
Absence MFA + mots de passe non formalisés	A07:2025 – Authentication Failures
Kali sur serveur de prod	A06:2025 – Insecure Design
NAS unique (sauvegarde + stockage)	A06 Insecure Design (défaut de conception : pas de séparation des fonctions, pas de copie hors-ligne)
Accès administrateur concentré	A01:2025 – Broken Access Control

3. Le NAS Synology « dédié à la sauvegarde ET au stockage » → point unique de défaillance, racine de **SO2 (ransomware)** ; la formulation même du document (un seul NAS pour deux fonctions) est un élément parlant à citer.
4. La VM Kali sur le même HP ProLiant que les VMs de prod → racine de **SO4** (cloisonnement labo/prod).
5. Le niveau 3 revendiqué avec « politique de mots de passe non formalisée » et « absence de MFA systématique » → ce sont les écarts qui font monter la vraisemblance de **SO1**, et le lien direct avec ton slide de **réserve maturité + la doctrine Zero Trust (MFA = pilier identité)**.

CHAPITRE 2 – EBIOS RM — SAN-log_it

Note de cadrage

Ce document applique la méthode **EBIOS Risk Manager** (ANSSI, 2018) au périmètre propre de **SAN-log_it**. La particularité de l'objet d'étude est que **SAN-log_it** est elle-même un prestataire technique : elle conçoit, déploie et administre des infrastructures pour des **PME** et accède donc, par nature, à des systèmes d'information clients.

Le **profil de risque dominant** n'est donc pas seulement « **protéger mes données** », mais aussi « **ne pas devenir un vecteur de compromission de mes clients** » — c'est-à-dire un risque de **chaîne d'approvisionnement (supply chain)**, côté prestataire.

Deux contraintes structurantes sont prises en compte tout au long de l'analyse :

(1) **SAN-log_it** est une **structure mono-personne**, ce qui concentre les accès, la connaissance et la disponibilité sur le gérant .

(2) **la maturité cyber** est estimée à **niveau 3/5 selon la grille ANSSI** (supervision active, segmentation, **IDS**), avec des écarts connus (politique de mots de passe non formalisée, absence de certification, pas de **SIEM**).

Conformément à la méthode, **toute information non vérifiée maintient la cotation la plus prudente**. Les niveaux de gravité et de vraisemblance utilisent une échelle à 4 paliers adaptée à une TPE.

Points à arbitrer / lever lors de la relecture

- **Le NAS Synology** dispose-t-il d'une copie de sauvegarde hors-ligne ou immuable (règle 3-2-1) et un test de restauration a-t-il déjà été réalisé et documenté ?
- **Les accès clients** (comptes admin, VPN, clés SSH) sont-ils stockés dans un coffre-fort de secrets dédié, protégés par MFA, et révoqués en fin de mission ?
- **La VM Kali Linux** partage-t-elle le même hyperviseur / segment que les services et les accès clients, ou est-elle réellement cloisonnée ?
- **Existe-t-il un mécanisme de continuité** en cas d'indisponibilité prolongée du gérant (partenaire de secours, documentation transférable) ?

Atelier 1 — Cadrage et socle de sécurité

Objet d'étude, valeurs métier, biens supports, socle de sécurité et événements redoutés.

1.1 — Objet d'étude et missions

L'objet d'étude est l'**activité de SAN-log_it** : la conception, le déploiement, l'administration et la sécurisation d'infrastructures systèmes et réseaux pour des **PME** (20 à 50 collaborateurs), réalisées sous forme de missions ponctuelles, directement ou en sous-traitance d'**ESN**.

L'analyse intègre le laboratoire technique virtualisé et l'ensemble des accès détenus sur les environnements clients.

Niveau	Description
Missions	Concevoir, déployer, administrer et sécuriser des infrastructures (AD/DNS/DHCP, segmentation, pare-feu, supervision) ; former les utilisateurs. Cas d'usage représentatif : visioconférence souveraine Jitsi Meet.
Valeurs métier	Processus et informations indispensables aux missions (voir 1.2).
Biens supports	Infrastructure du laboratoire, poste d'administration, secrets et accès clients, sauvegardes (voir 1.3).

Atteintes redoutées aux valeurs métier, évaluées selon les critères **DICT** (**Disponibilité, Intégrité, Confidentialité, Traçabilité**) et une échelle de gravité à 4 niveaux.

VM = Valeur métier

Réf.	Valeur métier	Nature	DICT prioritaire
VM1	Accès aux infrastructures clientes (comptes admin, comptes AD, VPN, clés SSH)	Information / secret	C+++ I++
VM2	Configurations et livrables techniques (Masters, configs pfSense/AD versionnées, documentation)	Information / processus	I+++ D++
VM3	Données clientes manipulées en mission (techniques, parfois personnelles)	Information	C+++ I++
VM4	Laboratoire technique virtualisé (validation avant production)	Processus / outil	D++ I++
VM5	Sauvegardes et référentiel documentaire (NAS Synology)	Information	D+++ I+++
VM6	Réputation et relation ESN / clients (capacité à obtenir des missions)	Immatériel	I+++ C++
VM7	Disponibilité opérationnelle du gérant (compétence, connaissance)	Ressource humaine	D+++

1.2 — Valeurs métier1.3 — Biens supports

Les biens supports portent les valeurs métier ci-dessus. La concentration sur peu d'équipements et sur une seule personne est un facteur aggravant à garder en mémoire.

Bien support	Valeurs métier portées
HP ProLiant DL380 (hyperviseur, VMs)	VM2, VM3, VM4
NAS Synology (sauvegardes, configs, doc client)	VM2, VM3, VM5
Switch Cisco CBS350 (VLAN) / Pare-feu pfSense + IDS Suricata	VM4, sécurité périmétrique
Poste d'administration du gérant (portable)	VM1, VM2, VM6, VM7 — point pivot
Coffre-fort de secrets / credentials clients, accès VPN	VM1 — actif le plus sensible
VM Kali Linux (outils offensifs de test)	VM4 — bien support à double tranchant
Dépôts de configurations / images (versioning)	VM2
Compte cloud (demos, supervision)	VM3, VM4
Messagerie / outils collaboratifs / connexion Internet	VM6, exposition

1.4 — Socle de sécurité (évaluation des écarts)

Évaluation par référentiel. **Vert** = appliqué ; **orange** = partiel ; **rouge** = non appliqué. La cotation reste prudente tant qu'une preuve n'est pas apportée.

Mesure / Référentiel	Statut	Faible / Constat
RGPD — sous-traitant (Art. 28 / 32)	⚠ Partiel	Journalisation des accès admin et sécurisation des flux en place. Registre des traitements en tant que sous-traitant et clauses Art. 28 à formaliser systématiquement.
NIS2 — gestion risques / notification	⚠ Partiel	Segmentation, supervision, IDS présents (compliance-ready). Procédure de notification d'incident et chaîne d'alerte non formalisées.
ANSSI — Guide d'hygiène	⚠ Partiel	MAJ, logs, segmentation OK. Politique de mots de passe non formalisée ; MFA non systématique sur les accès sensibles.
CIS Benchmarks (Windows/Linux/réseau)	⚠ Partiel	Scripts de durcissement des VMs. Conformité continue non mesurée / non documentée.
Gestion des secrets et des accès clients	✗ À renforcer	Credentials clients sensibles : MFA, cloisonnement et révocation en fin de mission à garantir.
Sauvegardes (3-2-1 / immuabilité)	⚠ Partiel	NAS + sauvegardes versionnées. NAS = point unique : copie hors-ligne/immuable et test de restauration à confirmer.
Cloisonnement labo / production / accès client	✗ À formaliser	Kali et services potentiellement sur le même hyperviseur/segment : isolation à valider.
Plan de réponse à incident / continuité	✗ appliqué Non	Pas de PRA/PCA formalisé : risque accru pour une structure mono-personne.
ISO/IEC 27001 — SMSI	✗ appliqué Non	Cible affichée: pas de système de management formalisé à ce jour.

1.5 — Événements redoutés

Atteintes redoutées aux valeurs métier, évaluées selon les critères **DICT** (**Disponibilité, Intégrité, Confidentialité, Traçabilité**) et une échelle de gravité à 4 niveaux.

Réf.	Événement redouté	VM	Gravité
ER1	Compromission des accès clients permettant un rebond vers une infrastructure cliente	VM1	Critique
ER2	Compromission / vol des secrets et du poste d'administration du gérant	VM1, VM2	Critique
ER3	Fuite de données clientes manipulées en mission	VM3	Majeure
ER4	Altération d'un livrable / config / Master avant déploiement chez le client	VM2	Majeure
ER5	Perte ou chiffrement des sauvegardes et de la documentation (NAS)	VM5	Majeure
ER6	Atteinte à la réputation / perte de confiance ESN-client	VM6	Majeure
ER7	Indisponibilité du laboratoire ou de l'infrastructure SAN-log_it	VM4, VM7	Significative
ER8	Exposition involontaire d'un service du laboratoire sur Internet	VM4	Significative

Atelier 2 — Sources de risque

Question centrale : « *Qui pourrait m'attaquer, et pourquoi ?* »

Chaque couple source de risque : **Objectif visé (SR/OV)** est coté selon la **Motivation, les Ressources et l'Activité**, pour en déduire une pertinence. Échelle : + faible, ++ moyen, +++ élevé.

Source de risque	Objectif visé	Mot.	Res.	Act.	Pertinence
SR1 — Cybercriminel / ransomware-as-a-service	Lucratif : chiffrer NAS + VMs, double extorsion	+++	++	+++	Élevée
SR2 — Groupe organisé / courtier d'accès (access broker)	Lucratif via supply chain : revendre les accès clients atteints via le prestataire	+++	+++	++	Élevée
SR3 — Acteur étatique / APT	Espionnage / pré-positionnement : prestataire comme porte d'entrée vers des PME ou via la sous-traitance ESN	++	+++	+	Moyenne
SR4 — Concurrent / officine spécialisée	Espionnage économique : vol de méthodologie, devis, portefeuille client	++	++	+	Moyenne
SR5 — Client malveillant ou client compromis	Défi / Lucratif : abuser de la relation ou retourner l'accès accordé	+	+	++	Moyenne
SR6 — Attaquant opportuniste / scan de masse	Lucratif / Défi : exploiter un service exposé du labo ou une CVE non corrigée	++	+	+++	Élevée
SR7 — Négligence du gérant (interne)	Sans intention : erreur de configuration, secret exposé, perte de matériel	—	—	+++	Élevée

Couples retenus en priorité pour les ateliers suivants : **SR1, SR2, SR6 et SR7** (pertinence élevée). **SR3** est conservé pour son impact maximal malgré une vraisemblance plus faible.

SR7 (négligence) n'est pas une source intentionnelle mais alimente directement plusieurs scénarios opérationnels et reste donc traité.

Atelier 3 — Scénarios stratégiques

Question centrale : « Par où passerait un attaquant dans mon écosystème ? »

3.1 — Parties prenantes de l'écosystème

Cotation selon la formule ANSSI : **Niveau de menace** = (**Dépendance** × **Pénétration**) / (**Maturité cyber** × **Confiance**), chaque critère noté de 1 à 4. Une menace ≥ 3 place la partie prenante en zone Danger.

Partie prenante	Catégorie	Dép.	Pén.	Mat.	Conf.	Menace / Zone
ESN partenaires	Partenaire / donneur d'ordre	4	3	2	3	2.0 — Contrôle
Clients PME	Client	4	2	1	3	2.7 — Contrôle
Fournisseur cloud (hébergement)	Partenaire	3	4	4	4	0.75 — Veille
Éditeurs / projets open-source (pfSense, Jitsi, OS)	Chaîne logicielle	4	4	2	3	2.7 — Contrôle
Partenaires sous-traités (audit, dev)	Partenaire	2	2	2	3	0.67 — Veille
FAI / routeur opérateur	Fournisseur	3	2	3	3	0.67 — Veille

Les trois parties prenantes en zone Contrôle — **ESN partenaires, clients PME et chaîne logicielle open-source** — concentrent l'essentiel des chemins d'attaque vers et via SAN-log_it.

3.2 — Scénarios stratégiques SS1 à SS6

Réf.	Source de risque	Objectif visé	Chemin stratégique	Gravité
SS1	Cybercriminel + Groupe organisé	Rebond vers une PME cliente	Compromission de SAN-log_it (poste/secrets) → réutilisation des accès admin/VPN clients → intrusion dans l'infra d'une ou plusieurs PME → ransomware / exfiltration côté client.	Très élevé
SS2	Cybercriminel	Infra SAN-log_it (NAS + hyperviseur)	Phishing ou service exposé → exécution sur l'hyperviseur → chiffrement des VMs et du NAS → perte simultanée des sauvegardes, configs et documentation.	Très élevé
SS3	Cybercriminel + Négligence	Secrets et accès du gérant	Perte/vol du portable ou vol du coffre de secrets sans MFA → accès direct à l'ensemble des credentials clients → pivot multi-clients.	Très élevé
SS4	Acteur étatique / Groupe organisé	Chaîne logicielle (Master/config)	Compromission d'un dépôt de configs/Master (pas de MFA, pas de signature) → image altérée livrée et déployée chez le client → implant persistant.	Élevé
SS5	Cybercriminel via ESN	Accès partagés ESN	Compromission d'un compte/poste d'une ESN partenaire partageant des accès clients → mouvement vers les environnements communs → atteinte indirecte de SAN-log_it et de ses clients.	Élevé
SS6	Attaquant opportuniste	Service exposé du labo / cloud	Scan de masse → exploitation d'une CVE non corrigée ou d'un service de démo cloud mal configuré → prise de pied → pivot vers production et accès clients.	Élevé

Atelier 4 — Scénarios opérationnels

Question centrale : « *Comment se déroulerait concrètement l'attaque ?* » Chaque scénario opérationnel (SO) est coté en vraisemblance et gravité pour en déduire un niveau de risque.

4.1 — Matrice de risques

Réf.	Scénario opérationnel	Vraisemblance	Niveau
SO1	Phishing du gérant → vol des credentials du coffre de secrets → accès clients	Vraisemblable	CRITIQUE
SO2	Ransomware via service exposé / CVE non corrigée → chiffrement NAS + VMs → perte des sauvegardes	Vraisemblable	CRITIQUE
SO3	Accès client non révoqué en fin de mission → réutilisation frauduleuse ultérieure	Vraisemblable	ÉLEVÉ
SO4	Cloisonnement insuffisant labo Kali ↔ production/accès client → propagation latérale	Possible	ÉLEVÉ
SO5	Compromission d'un dépôt de configs/Master (sans MFA, sans signature) → livraison altérée	Possible	ÉLEVÉ
SO6	Perte / vol du portable d'administration non chiffré ou déverrouillé → secrets exposés	Possible	ÉLEVÉ
SO7	Indisponibilité prolongée du gérant unique → arrêt de mission, perte de connaissance	Vraisemblable	ÉLEVÉ

Atelier Use Cases — Validation par cas d’usage

Chaque cas d’usage décrit le déroulement concret d’un scénario, pas à pas, afin de valider sa vraisemblance. Un scénario dont chaque étape est franchissable sans obstacle = vraisemblance maximale.

UC-01 — Phishing du gérant et rebond vers un client

Acteur(s)	Cybercriminel externe. Gérant SAN-log_it (victime). Une ou plusieurs PME clientes (victimes finales).
Préconditions	Le gérant utilise un coffre de secrets contenant les accès clients. MFA non systématique. Poste d’administration unique.

Déroulement :

1. L’attaquant envoie un courriel ciblé (facture **ESN**, alerte fournisseur) au gérant, dont l’adresse est aisément trouvable (OSINT, sous-traitance affichée).
2. Le gérant saisit ses identifiants sur une page de connexion factice. En l’absence de MFA généralisé, le compte est compromis.
3. L’attaquant accède au coffre de secrets ou à la messagerie et récupère les credentials admin/VPN de plusieurs clients.
4. Il se connecte au VPN d’une PME cliente avec un compte d’administration légitime – **aucune alerte côté client**.
5. Mouvement latéral dans l’Active Directory du client, exfiltration puis déploiement d’un ransomware.
6. L’incident est attribué à **SAN-log_it** (accès tracé à son compte) : responsabilité contractuelle et réputationnelle engagée.

Résultat / Impact	Compromission en chaîne d’un ou plusieurs clients via le prestataire. Atteinte directe à VM1 et VM6 . Responsabilité de sous-traitant engagée.
Scénario EBIOS	SO1 — Vraisemblance : Vraisemblable. Gravité : Très élevé. CRITIQUE.
Réglementation	RGPD Art. 28/32/33 — NIS2 (notification) — responsabilité contractuelle vis-à-vis du client.

UC-02 — Ransomware sur le NAS et perte des sauvegardes

Acteur(s)	Cybercriminel (affilié ransomware). Infrastructure SAN-log_it .
Préconditions	NAS Synology servant à la fois de sauvegarde et de stockage. Copie hors-ligne/immuable non confirmée. Pas de SIEM .

Déroulement :

7. Un service de démonstration ou d'accès distant est exposé sur Internet avec une **CVE** non corrigée (cf. veille CVE en cours).
8. L'attaquant obtient l'exécution de code sur une **VM**, puis remonte vers l'**hyperviseur** (HP ProLiant).
9. Découverte du **NAS** monté sur le réseau ; les partages de sauvegarde sont accessibles avec les droits de l'hôte compromis.
10. Chiffrement simultané des **VMs** et des **partages NAS** (configs clients, documentation, sauvegardes).
11. Sans copie hors-ligne ni test de restauration, la remise en service est incertaine ; la capacité à honorer les missions en cours s'effondre.
12. Demande de rançon ; risque de divulgation des configurations et données clientes.

Résultat / Impact	Perte simultanée du stockage et des sauvegardes : configurations, documentation et données clientes chiffrées (VM2, VM3, VM5). Le NAS unique étant un point de défaillance, la reprise peut être impossible. Atteinte directe à la disponibilité et à l'intégrité ; réputation engagée (VM6).
Scénario EBIOS	SO2 — Vraisemblance : Vraisemblable. Gravité : Très élevé. CRITIQUE.
Réglementation	RGPD Art.32 (sécurité des traitements) / Art. 33 (notification de violation sous 72 h) — NIS2 (notification d'incident) — obligation contractuelle de continuité.

UC-03 — Accès client résiduel non révoqué

Acteur(s)	Gérant (négligence). Tiers opportuniste ou attaquant ultérieur.
Préconditions	À la fin d'une mission, les comptes/accès créés pour SAN-log_it ne font pas l'objet d'une procédure de clôture systématique.

Déroulement :

13. Une mission de déploiement se termine ; le client n'a pas de DSI pour réviser les accès.
14. Le compte d'administration et l'accès VPN de SAN-log_it restent actifs côté client.
15. Plusieurs semaines après, ces identifiants figurent dans un lot de credentials revendu après une fuite sans lien direct.
16. Un attaquant teste l'accès VPN du client : il est toujours valide.
17. Intrusion silencieuse dans l'infrastructure cliente, sans qu'aucune partie ne sache que l'accès aurait dû être supprimé.
18. L'origine remonte au prestataire, qui n'a pas tracé ni clos ses accès.

Résultat / Impact	Intrusion cliente via un accès qui aurait dû être révoqué. Atteinte VM1 , responsabilité partagée mais réputation du prestataire engagée.
Scénario EBIOS	SO3 — Vraisemblance : Vraisemblable. Gravité : Élevé. ÉLEVÉ.
Réglementation	RGPD Art. 5/32 — ANSSI (gestion des accès) — clause contractuelle de fin de mission.

UC-04 — Indisponibilité du gérant unique

Acteur(s)	Aucun attaquant. Aléa (maladie, accident, indisponibilité prolongée).
Préconditions	Structure mono-personne : toute la connaissance, les accès et la relation client reposent sur le gérant. Pas de back-up humain formalisé.

Déroulement :

19. Le gérant devient indisponible de façon imprévue durant plusieurs semaines.
20. Les missions en cours s'arrêtent ; les clients sans DSI n'ont pas d'interlocuteur de repli.
21. La documentation existe mais n'est pas pensée pour être reprise par un tiers (conventions implicites, secrets non transférables).
22. Un incident survient chez un client pendant cette période : personne ne peut intervenir ni fournir les accès.
23. Les engagements ne sont pas tenus ; perte de confiance des ESN et des clients.

Résultat / Impact	Rupture de continuité (VM7). Pas d'atteinte à la confidentialité, mais impact direct sur la disponibilité du service et la réputation (VM6).
Scénario EBIOS	SO7 — Vraisemblance : Vraisemblable. Gravité : Critique. ÉLEVÉ.
Réglementation	Obligation de moyens contractuelle — pas de cadre réglementaire spécifique, mais enjeu de pérennité.

UC-05 — Cloisonnement insuffisant labo Kali ↔ production

Acteur(s)	Attaquant ayant pris pied sur la VM Kali, ou détournement de l'outillage offensif / négligence de configuration. Infrastructure SAN-log_it (production et accès clients).
Préconditions	VM Kali Linux hébergée sur le même hyperviseur (HP ProLiant) et/ou le même segment réseau que les VMs de production et les accès clients. Cloisonnement logique non garanti.

Déroulement :

24. **La VM Kali** — outil offensif de test — est compromise ou détournée (script resté actif, outil porteur d'une charge, rebond depuis une mission).
25. **Faute de VLAN dédié**, la VM Kali atteint en réseau les VMs de production et le poste d'administration situés sur le même segment.
26. **L'attaquant exploite la co-résidence** sur l'hyperviseur (isolation faible, hyperviseur non durci) pour viser les autres VMs.
27. **Mouvement latéral** vers les services de production puis vers les secrets et accès clients hébergés dans le périmètre.
28. **L'environnement de test**, censé être jetable, devient le point d'entrée vers les actifs les plus sensibles.

Résultat / Impact	Propagation du laboratoire vers la production et les accès clients (VM1, VM4). Un environnement conçu comme « bac à sable » contamine le périmètre opérationnel. Atteinte à la confidentialité et à l'intégrité.
Scénario EBIOS	SO4 — Vraisemblance : Possible. Gravité : Élevé. ÉLEVÉ. (OWASP A06:2025 — Insecure Design.)
Réglementation	ANSSI (cloisonnement, guide d'hygiène) — RGPD Art. 32 (sécurité par cloisonnement) — CIS Benchmarks (durcissement de l'hyperviseur).

UC-06 — Compromission du dépôt de configurations / Master (supply chain)	
Acteur(s)	Acteur étatique / groupe organisé (objectif : implant persistant). SAN-log_it (prestataire, vecteur). Une ou plusieurs PME clientes (victimes finales).
Préconditions	Dépôt de configurations et d'images Master versionnées, sans MFA ni signature / vérification d'intégrité. Masters réutilisés d'un client à l'autre.

Déroulement :

- 29. L'attaquant obtient un accès** au dépôt de configs / Masters (credential exposé, absence de MFA, compte du gérant compromis).
- 30. Il altère discrètement une image Master ou un script de configuration** (porte dérobée, compte caché, règle pfSense modifiée).
- 31. Aucune signature ni hachage** ne permet de détecter l'altération avant déploiement.
- 32. SAN-log_it déploie le Master altéré chez un ou plusieurs clients, en toute bonne foi.**
- 33. L'implant persiste dans l'infrastructure cliente** : point d'entrée durable ou pré-positionnement.
- 34. La compromission se propage à l'échelle du portefeuille via la réutilisation des Masters — effet supply chain.**

Résultat / Impact	Compromission en chaîne des clients via un livrable altéré (VM2, VM1). Le prestataire devient vecteur de compromission ; responsabilité contractuelle et réputationnelle majeure (VM6).
Scénario EBIOS	SO5 — Vraisemblance : Possible. Gravité : Élevé. ÉLEVÉ. (OWASP A03:2025 — Software Supply Chain Failures.)

Réglementation	RGPD Art. 28 (sous-traitant) / Art. 32 — NIS2 (sécurité de la chaîne d’approvisionnement) — responsabilité contractuelle vis-à-vis du client.
----------------	--

UC-07 — Perte ou vol du portable d’administration

Acteur(s)	Tiers opportuniste (vol, perte) ou attaquant ciblé. Gérant SAN-log_it (victime). Une ou plusieurs PME clientes (victimes finales).
Préconditions	Poste d’administration unique (point pivot) contenant ou donnant accès au coffre de secrets, aux sessions VPN et aux credentials clients. Chiffrement de disque et MFA non garantis.

Déroulement :

- 35. Le portable d’administration du gérant** est perdu ou volé (déplacement, mission sur site client, domicile).
- 36. En l’absence de chiffrement intégral** du disque, le contenu est lisible hors session.
- 37.** Le coffre de secrets ou les sessions / identifiants enregistrés donnent accès aux credentials admin/VPN de plusieurs clients.
- 38.** Sans MFA, ces accès sont directement réutilisables.
- 39.** L’attaquant pivote vers une ou plusieurs infrastructures clientes avec des comptes légitimes — aucune alerte côté client.

Résultat / Impact	Exposition de l’actif le plus sensible (VM1) via le point pivot (VM2 , VM7). Un seul objet perdu suffit à compromettre l’ensemble des accès clients. Atteinte critique à la confidentialité.
Scénario EBIOS	SO6 — Vraisemblance : Possible. Gravité : Élevé. ÉLEVÉ.
Réglementation	RGPD Art. 32 (chiffrement) / Art. 33 (notification) — ANSSI (sécurité des terminaux nomades).

Atelier 5 — Traitement du risque

Plan d'action priorisé : P1 immédiat, P2 court terme, P3 moyen terme. Les mesures visent à ramener les risques critiques à un niveau acceptable pour une TPE.

Prio	Risque	Mesure	Délai
P1	R1/R2 (SO1, SO6)	Activer le MFA sur tous les accès sensibles (coffre de secrets, messagerie, comptes admin clients, VPN). Chiffrer intégralement le poste d'administration (BitLocker/LUKS) + verrouillage automatique. Coffre de secrets dédié.	< 30 j
P1	R2 (SO2)	Mettre en place une sauvegarde 3-2-1 avec une copie hors-ligne ou immuable. Réaliser et documenter un premier test de restauration.	< 30 j
P1	R3 (SO3)	Créer une checklist de clôture de mission : inventaire et révocation des comptes/accès créés, restitution au client. Tenir un registre des accès clients détenus.	< 30 j
P2	R4 (SO4)	Cloisonner réellement le laboratoire : VLAN dédié, hyperviseur ou poste distinct pour Kali. Interdire tout accès client depuis l'environnement de test.	< 90 j
P2	R5 (SO5)	Sécuriser le dépôt de configurations/Masters : MFA, protection de branches, hachage/signature des images, vérification d'intégrité avant livraison.	< 90 j
P2	Socle	Formaliser la politique de mots de passe, un plan de réponse à incident allégé, le registre RGPD de sous-traitant (Art. 28).	< 90 j
P2	SO6/exposition	Cadencer le patch management ; durcir/supprimer les services exposés ; poursuivre la veille CVE (Livable A).	< 90 j
P3	Tous	Déployer un SIEM léger (ELK) pour une vision unifiée des logs et une détection cohérente avec NIS2.	< 6 mois

P3	R-continuité (SO7)	Mettre en place un partenaire de secours, une documentation transférable et une clause de réversibilité. Souscrire une assurance RC Pro / cyber.	< 6 mois
P3	Maturité	Engager une auto-évaluation ANSSI documentée puis une démarche de certification (ISO 27001 / SecNumCloud-ready) pour passer du niveau 3 vers 4.	Continu

Verdict — Synthèse pour le gérant

Ce qui est solide	Ce qui doit être corrigé
- Maturité technique réelle (niveau 3/5) : segmentation VLAN, pare-feu pfSense, IDS Suricata, supervision Prometheus/Grafana. - Validation en laboratoire avant production : réduit fortement le risque d'erreur de configuration. - Conscience réglementaire (RGPD, NIS2, ANSSI, CIS) et veille CVE déjà amorcée.	- Le risque dominant est le rebond vers les clients (supply chain) : les accès clients sont l'actif le plus sensible et doivent être protégés par MFA, cloisonnés et révoqués. - Le NAS est un point unique : sans copie immuable ni test de restauration, un ransomware est potentiellement irréversible. - La concentration sur une seule personne crée un risque de continuité (SO7) sans équivalent de mesure technique.

En synthèse : SAN-log_it présente une posture technique cohérente avec son positionnement, mais son profil de risque est celui d'un **prestataire-pivot**,

Les trois priorités absolues sont :

- (1) Protéger et cloisonner** les accès clients (MFA, coffre, révocation).
- (2) Sécuriser les sauvegardes** contre le ransomware (3-2-1 immuable + test).
- (3) Traiter la continuité liée au gérant unique**. Ces mesures, peu coûteuses, font passer la structure d'une maîtrise « technique » à une maîtrise « gouvernée », condition de crédibilité vis-à-vis des **ESN** et des **PME**.



Synthèse Zero Trust — Constat → OWASP 2025 → Principe → Mesure

Section transversale reliant le préambule OWASP (chap. 1) au plan de traitement (Atelier 5)

Le modèle **Zero Trust** sert ici de doctrine de raccordement :

- Il fait le pont entre les **constats techniques** relevés à l'audit.
- Les **vulnérabilités génériques OWASP Top 10:2025** qui les qualifient.
- Les **scénarios opérationnels (SO)** qu'ils alimentent, et les **mesures de traitement** déjà priorisées à l'**Atelier 5**.

Chaque ligne se lit donc : *un constat → sa faille OWASP → le SO concerné → le principe Zero Trust qui le neutralise → la mesure concrète et son rang de priorité (PTR).*

Référentiels mobilisés :

1. **NIST SP 800-207** (architecture Zero Trust) et les **recommandations ANSSI** sur le sujet.
2. Pour une TPE prestataire-pivot comme SAN-log_it, le **pilier Identité** (MFA + révocation des accès) constitue le socle minimal : il neutralise à lui seul l'entrée des **deux scénarios CRITIQUES (SO1, et la chaîne menant à SO2).**

Tableau de correspondance

Constat (audit SAN-log_it)	OWASP Top 10:2025	SO	Principe Zero Trust	Mesure de traitement (réf. Atelier 5)
Accès admin concentré / non révoqué	A01:2025 Broken Access Control	SO1 · SO3	Moindre privilège + vérification continue Aucun accès permanent par défaut : comptes nominatifs, privilèges au plus juste, accès temporaires (JIT) et révoqués en fin de mission.	Comptes admin nominatifs ; registre des accès clients détenus ; checklist de clôture de mission (révocation systématique comptes/VPN) ; bascule vers des accès temporaires. → PTR P1 (R3/SO3) + P1 (R1/SO1)
Accès clients + dépôt de configs (rôle prestataire-pivot)	A03:2025 Software Supply Chain Failures	SO5	Assume breach + vérification explicite de l'intégrité Un Master ou une config n'est pas digne de confiance du seul fait qu'il vient du dépôt : on vérifie son intégrité avant livraison et on cloisonne par client.	MFA + protection de branches sur le dépôt ; signature / hachage des images et Masters ; vérification d'intégrité avant tout déploiement ; cloisonnement des environnements par client. → PTR P2 (R5/SO5)
Kali sur le serveur de production	A06:2025 Insecure Design	SO4	Micro-segmentation + Assume breach L'outillage offensif est isolé du reste : séparation stricte labo ↔ production ↔ accès client, sans confiance implicite entre segments.	VLAN dédié et hyperviseur (ou poste) distinct pour Kali ; interdiction de tout accès client depuis l'environnement de test ; isolation logique validée. → PTR P2 (R4/SO4)

NAS unique (sauvegarde + stockage)	A06:2025 Insecure Design (défaut de conception : pas de séparation des fonctions, pas de copie hors-ligne)	SO2	Assume breach + séparation des fonctions On présume le chiffrement de l'actif primaire : la sauvegarde doit être hors d'atteinte (immuable / hors-ligne) et séparée du stockage de production.	Sauvegarde 3-2-1 avec copie hors-ligne ou immuable ; séparation stockage / sauvegarde ; test de restauration réalisé et documenté. → PTR P1 (R2/SO2)
Absence de MFA + mots de passe non formalisés	A07:2025 Authentication Failures	SO1	Vérification explicite de l'identité (pilier Identité) Cœur de la doctrine : preuve d'identité forte à chaque accès sensible ; aucune confiance accordée au mot de passe seul.	MFA généralisé (coffre de secrets, messagerie, comptes admin clients, VPN) ; politique de mots de passe formalisée ; coffre de secrets dédié ; poste d'administration chiffré. → PTR P1 (R1/SO1, SO6)
Services exposés / cloud mal configuré	A02:2025 Security Misconfiguration	SO6-exposition · SS6	Réduction de la surface + visibilité continue Aucune surface n'est exposée par défaut : configuration durcie, auditée et surveillée en continu (« assume breach » appliqué à l'exposition).	Durcissement CIS (Windows/Linux/réseau) ; suppression / durcissement des services exposés ; patch management cadencé + veille CVE ; audit de la configuration cloud ; SIEM pour la visibilité. → PTR P2 (exposition) + P3 (SIEM)

Note de cohérence — les codes SO reprennent le mapping de travail tel quel. Le document comporte deux grilles SO (préambule, p. 8-9, et matrice de l'Atelier 4, p. 20) qui divergent sur SO5/SO6 ; la colonne mesure est donc ancrée sur le PTR de l'Atelier 5 (P1/P2/P3), référence de traitement non ambiguë. « SO6-exposition » renvoie au scénario « services exposés / cloud » du préambule, repris sous la ligne « P2 – exposition » du PTR.

Rappel doctrinal

Les trois doctrines ci-dessous couvrent l'intégralité du tableau. Elles recoupent directement les **trois priorités absolues** du verdict (p. 29) : protéger/révoquer les accès clients (Least Privilege + Verify), sécuriser les sauvegardes contre le ransomware (Assume Breach), et traiter la continuité du gérant unique.



Never Trust, Always Verify	Aucune confiance implicite : chaque demande d'accès est authentifiée et autorisée explicitement, quel que soit l'emplacement (interne ou externe).
Least Privilege	Droits réduits au strict nécessaire , dans le temps comme dans le périmètre (accès juste-à-temps, juste-assez).
Assume Breach	On conçoit l'architecture en supposant la compromission : micro-segmentation, limitation du rayon d'action, sauvegardes hors d'atteinte, journalisation et détection.